

Dossier Technique ECF — Vite & Gourmand

TP Développeur Web et Web Mobile (Studi) · Antoine Banzet · 2026

Informations obligatoires & liens du projet

- **Dépôt GitHub** : <https://github.com/antoinebaban-sketch/ECF-DWWW>
- **Outil de gestion de projet** : GitHub — jalons (sprints) et issues (tâches)
- **Déploiement (application en ligne)** : <https://ecf-dwww.onrender.com>
- **Identifiants administrateur** : `admin@viteetgourmand.fr` / `Admin2026!`

Partie 1 — Analyse des besoins

1.1 Résumé du projet

Vite & Gourmand est un traiteur haut de gamme installé à Bordeaux depuis 1999. Après plus de 25 ans d'activité, l'entreprise dispose d'une clientèle fidèle mais gère encore sa prise de commande par téléphone et par email. Le projet consiste à numériser l'ensemble de la chaîne : catalogue, commande, livraison et gestion interne.

L'application web et web mobile permet de consulter une carte de menus filtrables par régime alimentaire et par allergène, de passer commande en ligne avec calcul automatique de la tarification et des frais de livraison, de déposer un avis soumis à modération, et donne au personnel des espaces de gestion dédiés. Le système distingue **quatre profils** : le Visiteur (non authentifié, pages publiques uniquement), le Client, l'Employé et l'Administrateur.

L'architecture repose sur une **double base de données** — MySQL pour les données transactionnelles, MongoDB pour l'analyse décisionnelle de l'espace administrateur — une **API REST JSON en PHP natif** organisée selon le patron *Front Controller*, et un front-end HTML / CSS / JavaScript sans framework, conforme aux normes RGAA / WCAG 2.1 niveau AA.

1.2 Spécifications fonctionnelles

Module Client — Inscription (consentement RGPD obligatoire, case non pré-cochée), connexion, réinitialisation du mot de passe par lien à usage unique. Consultation dynamique du catalogue avec filtres stricts par régime et par allergène. Passage de commande avec choix de livraison au tarif kilométrique. Modification et annulation libres tant que la commande n'est pas passée au statut « acceptée ». Suivi du statut après acceptation, avec historique daté. Dépôt d'un avis sur une commande terminée. Demande de facture. Export de ses données personnelles (RGPD Art. 20) et suppression de compte (RGPD Art. 17, par pseudonymisation).

Module Employé — Gestion CRUD complète des menus, plats, régimes, allergènes et horaires. Gestion des commandes : changement de statut parmi les 8 étapes du cycle de vie, filtre par statut et par client. L'annulation ou la modification d'une commande après acceptation impose la saisie d'un motif et d'un mode de contact. Modération des avis clients avant publication.

Module Administration — Toutes les prérogatives de l'employé, plus la création et la désactivation de comptes employés (le mot de passe n'est jamais transmis en clair : l'employé définit le sien via un lien d'activation à usage unique). Accès au tableau de bord analytique : chiffre d'affaires par mois et par menu (calculé en SQL), nombre de commandes par menu (calculé en MongoDB, restitué sous forme de graphique comparatif).

Cycle de vie d'une commande : `en_attente` → `acceptée` → `en_preparation` → `en_cours_livraison` → `livrée` → `retour_materiel` → `terminée` ; annulée possible avant acceptation (par le client) ou à tout moment (par le personnel, avec motif).

Règles métier de l'énoncé : réduction automatique de 10 % lorsque le nombre de convives atteint le minimum requis majoré de 5 ; frais de livraison de 5 € forfaitaires + 0,59 €/km hors de Bordeaux ; retour du matériel loué sous 10 jours ouvrés, sous peine d'une pénalité de 600 € ; validation obligatoire des avis avant publication ; interdiction absolue de créer un compte administrateur depuis l'interface publique.

1.3 Méthodologie et suivi de projet

Projet mené en autonomie, selon une démarche **itérative et incrémentale**. Le séquençement s'est appuyé sur la progression pédagogique de la formation : les briques techniques ont été abordées dans l'ordre du cursus — intégration HTML / CSS, puis JavaScript, puis PHP et API REST, base

relationnelle MySQL, base NoSQL MongoDB, sécurité, et enfin déploiement. Ce découpage est suivi sur **GitHub** — 7 jalons (*milestones*) correspondant aux sprints, chacun décliné en tâches (*issues*) — et l'historique Git (commits atomiques et datés, branches de fonctionnalités) en constitue la trace détaillée.

Partie 2 — Spécifications techniques

2.1 Choix de la stack technique

Composant	Technologie	Justification
Backend / API	PHP 8.1 · PDO · API REST JSON Architecture Front Controller (sans framework)	Hébergement PHP standard, maîtrise totale de la logique et de la sécurité, aucune surcouche à apprendre ou maintenir dans les délais impartis.
SGBDR	MySQL 8+ · InnoDB · utf8mb4	Propriétés ACID, clés étrangères et contraintes d'intégrité référentielle indispensables pour une base de commandes ; relations Plusieurs-à-Plusieurs via tables de liaison.
NoSQL	MongoDB · pilote <code>ext-mongodb</code> (sans Composer)	Base non relationnelle exigée par l'énoncé ; <i>aggregation pipeline</i> pour découpler le calcul décisionnel du transactionnel.
Frontend	HTML5 · CSS3 (Custom Properties) · JavaScript vanilla (ES6+)	Compatibilité multi-support, conformité RGAA sans dépendance, aucune étape de build.
Authentification	Sessions PHP (cookie <code>HttpOnly</code> / <code>Secure</code>) · <code>bcrypt</code> cost 12	Mécanisme natif de PHP, aucun code cryptographique à écrire, cookie non lisible en JavaScript.
Emails	<code>mail()</code> natif en local · API HTTP Brevo en production	Un conteneur Docker n'embarque pas de serveur mail ; l'API HTTP de Brevo contourne cette limite en production.

2.2 Environnement de développement et de déploiement

Développement local — Stack XAMPP (Apache, PHP 8.x, MySQL 8+), base MongoDB hébergée sur MongoDB Atlas (cluster gratuit). Gestion de version : Git et dépôt GitHub. Organisation des branches : `main` (code stable / production), `develop` (intégration), et une branche `feature/*` par fonctionnalité, fusionnée dans `develop` avec `--no-ff` après test ; `develop` est fusionnée dans `main` pour marquer les versions stables. Messages de commit atomiques et préfixés (`feat` , `fix` , `chore` , `docs`).

Déploiement en production — Image Docker (base `php:8.1-apache`) déployée sur **Render**. Le script `docker-entrypoint.sh` adapte le port d'écoute d'Apache à la variable `$PORT` imposée par l'hébergeur. Base MySQL managée sur **Aiven** (connexion SSL via le certificat `api/aiven-ca.pem` , activé automatiquement dès que l'hôte de base n'est plus `localhost`). MongoDB sur **Atlas**. Emails via l'API HTTP de **Brevo**.

Isolation des variables sensibles — Le fichier `api/.env` n'est jamais versionné (listé dans `.gitignore`) ; un modèle `api/.env.example` documente les variables attendues. En production, les valeurs sont injectées par le tableau de bord de Render.

Procédure de mise à jour — Un `push` sur la branche déployée déclenche automatiquement la reconstruction et le redéploiement de l'image par Render. Les évolutions de schéma de base de données sont appliquées manuellement (phpMyAdmin en local, console Aiven en production).

2.3 Conception de la base de données relationnelle (MySQL)

La modélisation a suivi trois étapes : MCD (entités, associations, cardinalités, indépendamment de toute technique) → MLD (traduction relationnelle : tables, colonnes, placement des clés primaires et étrangères, relations N-N transformées en tables de liaison) → DDL (implémentation).

Choix techniques — Moteur **InnoDB** (et non MyISAM) pour les clés étrangères et les transactions ACID. Encodage **utf8mb4** (et non **utf8**, limité à 3 octets et incompatible avec certains caractères). Normalisation **3NF** : la table `commande` stocke `client_id` (clé étrangère) et non le nom ou l'email du client, qui n'ont donc pas à être dupliqués ni synchronisés.

Décisions structurantes

- **Prix historisé** — Le prix unitaire et le montant total sont figés au moment de la commande, jamais recalculés à l'affichage : principe comptable de la pièce justificative. Si le tarif d'un menu évolue, la facture initiale du client reste inchangée.
- **Pseudo-suppression des utilisateurs** — Une colonne `statut_compte` (0/1) désactive l'accès sans supprimer physiquement la ligne (ce qui casserait les clés étrangères des commandes passées). Le droit à l'effacement RGPD est traité par pseudonymisation (voir Partie 4).
- **Tables de liaison N-N** — Le schéma compte 6 relations Plusieurs-à-Plusieurs : menu ↔ plat, menu ↔ régime, plat ↔ allergène, plat ↔ régime, utilisateur ↔ régime, utilisateur ↔ allergène.

```
CREATE TABLE `menu_regime` (  
  `menu_id` INT NOT NULL,  
  `regime_id` INT NOT NULL,  
  PRIMARY KEY (`menu_id`, `regime_id`),  
  CONSTRAINT `fk_mr_menu` FOREIGN KEY (`menu_id`) REFERENCES `menu` (`menu_id`) ON DELETE CASCADE,  
  CONSTRAINT `fk_mr_regime` FOREIGN KEY (`regime_id`) REFERENCES `regime` (`regime_id`)  
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;
```

Le `ON DELETE CASCADE` sur `fk_mr_menu` nettoie automatiquement les liaisons lorsqu'un menu est supprimé. L'absence volontaire de cascade sur `fk_mr_regime` (comportement par défaut, `RESTRICT`) **bloque** la suppression d'un régime encore rattaché à des menus — garantie de cohérence pour les clients ayant des contraintes alimentaires.

2.4 Indexation et optimisation des performances

Sans index, MySQL effectue une lecture séquentielle complète (*Full Table Scan*), de complexité linéaire $O(n)$. Les index explicites construisent des arbres B-tree ramenant la recherche à une complexité logarithmique $O(\log n)$. Des index ont été créés sur les colonnes sollicitées par les clauses `WHERE`, `JOIN` et `ORDER BY` de l'API :

```
-- Espace client et suivi des commandes  
CREATE INDEX idx_commande_client ON `commande` (`client_id`);  
CREATE INDEX idx_commande_statut ON `commande` (`statut_commande`);  
CREATE INDEX idx_commande_date ON `commande` (`date_commande`);  
CREATE INDEX idx_commande_menu ON `commande` (`menu_id`);  
  
-- Modération des avis  
CREATE INDEX idx_avis_statut ON `avis` (`statut_validation`);  
CREATE INDEX idx_avis_client ON `avis` (`client_id`);  
  
-- Contrôle d'accès (RBAC)  
CREATE INDEX idx_utilisateur_role ON `utilisateur` (`role_id`);
```

2.5 Base de données NoSQL (MongoDB)

Conformément à l'énoncé, MongoDB est exploité **exclusivement** pour l'analyse décisionnelle du tableau de bord administrateur : la visualisation du nombre de commandes par menu. Son usage n'a volontairement pas été étendu à un système de logs ou à la gestion de sessions, pour rester dans le périmètre demandé et garder une séparation nette des responsabilités.

Chaque commande enregistre, **dès sa création**, un document dans la collection `commandes` :

```
{
  "_id": ObjectId("6693f1a2e4b0a123456789ab"),
  "commande_id": 157,
  "menu_id": 8,
  "menu_titre": "Menu Prestige Bordeaux",
  "montant": 2550.00,
  "date": "2026-07-14"
}
```

Le comptage s'appuie sur un *aggregation pipeline*, équivalent d'un `GROUP BY` + `COUNT`. Le regroupement se fait sur `$menu_id` (et non sur le titre) pour éviter toute collision entre deux menus homonymes ; le titre est récupéré via `$first` :

```
db.commandes.aggregate([
  { $group: {
    _id: "$menu_id",
    menu_titre: { $first: "$menu_titre" },
    nb_commandes: { $sum: 1 }
  }},
  { $sort: { nb_commandes: -1 } }
]);
```

Séparation des responsabilités — MongoDB ne fait que du comptage (`nb_commandes`). Le calcul financier du chiffre d'affaires reste traité par MySQL via une requête dédiée, garantissant l'étanchéité entre gestion comptable et outil décisionnel.

Dégradation gracieuse — Si `MONGO_URI` n'est pas renseignée ou si le serveur MongoDB est indisponible, l'application entière continue de fonctionner : prise de commande et navigation restent 100 % opérationnelles. Seul le bloc graphique de l'espace administration affiche « Aucune donnée (MongoDB non configuré ?) ». Un service d'analyse secondaire ne doit jamais bloquer le cœur de métier.

2.6 Mécanismes de sécurité — grille OWASP Top 10

Menace OWASP	Risque	Mécanisme déployé
A01 — Broken Access Control	Appel non autorisé d'endpoints API	Session PHP (cookie <code>HttpOnly</code>) + contrôle de rôle systématique côté serveur (<code>roleRequired()</code>), jamais uniquement côté frontend.
A02 — Cryptographic Failures	Compromission des mots de passe	Hachage <code>bcrypt</code> cost 12 via <code>password_hash()</code> (~250 ms par hachage, débit d'un attaquant fortement limité). Jamais de stockage en clair.
A03 — Injection SQL	Injection de code via les formulaires	100 % des requêtes touchant une donnée utilisateur passent par des requêtes préparées PDO avec paramètres liés (<code>PDO::ATTR_EMULATE_PREPARES = false</code> : vraies requêtes préparées côté serveur).
A03 — Cross-Site Scripting (XSS)	Injection de scripts via les champs libres	Double protection : <code>strip_tags()</code> côté serveur avant stockage, échappement HTML (<code>escapeHtml()</code>) côté client à l'affichage de toute donnée saisie par un utilisateur.

Périmètre XSS — L'échappement est systématique sur les données saisies par le public (avis, formulaires, profil). Les libellés de catalogue affichés côté public (titres de menus, plats, régimes, allergènes) ne sont pas échappés de façon exhaustive : ils sont gérés exclusivement par le personnel via des routes protégées (`roleRequired('employe', 'administrateur')`). Le risque y est limité au cas d'un compte staff compromis — hors du périmètre de menace principal, mais identifié comme axe d'amélioration.

Ne sont **pas** implémentés (non demandés par l'énoncé, ajoutés seulement avec un besoin identifié) : reCAPTCHA, double authentification, limitation de débit anti-bruteforce.

Partie 3 — Recherche & veille technologique (documentation anglophone)

3.1 Situation de travail ayant nécessité une recherche anglophone

Lors de l'implémentation du hachage des mots de passe avec `password_hash()` et l'algorithme `PASSWORD_BCRYPT`, il a fallu déterminer la valeur du **facteur de coût** (`cost`) : ce paramètre fixe la difficulté de calcul du hachage. Une valeur trop basse rend le hachage vulnérable à une attaque par force brute sur une base volée ; une valeur trop haute ralentit chaque connexion et charge inutilement le serveur. La documentation officielle de PHP, disponible uniquement en anglais dans sa version de référence, précise la démarche à suivre.

Source : *PHP Manual* — `password_hash`, php.net/manual/en/function.password-hash.php (section « Supported options for PASSWORD_BCRYPT » et « Notes »).

3.2 Extrait anglophone et traduction

Extrait original (anglais)

« *cost* (int) — which denotes the algorithmic cost that should be used. Examples of these values can be found on the `crypt()` page. If omitted, a default value of 12 will be used. This is a good baseline cost, but it should be adjusted depending on hardware used. »

« *Note: It is recommended to test this function on the machine used, adjusting the cost parameter(s) so that execution of the function takes less than 350 milliseconds for interactive logins. »*

Traduction en français

« *cost* (entier) — désigne le coût algorithmique à utiliser. Des exemples de ces valeurs se trouvent sur la page `crypt()`. S'il est omis, une valeur par défaut de 12 est utilisée. C'est un bon coût de référence, mais il doit être ajusté selon le matériel utilisé.

Note : il est recommandé de tester cette fonction sur la machine utilisée, en ajustant le paramètre de coût de sorte que son exécution prenne moins de 350 millisecondes pour les connexions interactives. »

3.3 Décision retenue

J'ai fixé explicitement `['cost' => 12]` dans la fonction `hashPassword()` (`api/helpers.php`). Ce choix correspond au coût de référence recommandé par PHP ; sur l'environnement de test, un hachage prend environ 250 ms, bien en dessous du seuil de 350 ms préconisé pour ne pas dégrader l'expérience de connexion, tout en restant assez lent pour limiter fortement le débit d'un attaquant. La valeur est écrite en dur plutôt que laissée implicite, afin que le comportement reste stable même si la valeur par défaut de PHP évolue dans une version ultérieure.

Partie 4 — Conformité RGPD et accessibilité RGAA

4.1 Conformité RGPD et pseudonymisation

Bases légales des traitements — Consentement explicite à l'inscription (case à cocher non pré-cochée, tracée en base) ; exécution d'un contrat pour la prise de commande ; intérêt légitime pour les emails transactionnels. Aucun cookie tiers (analytics, publicité).

Droits implémentés — Accès (Art. 15) et rectification (Art. 16) via l'espace profil ; portabilité (Art. 20) par export JSON téléchargeable ; effacement (Art. 17).

Conflit droit à l'effacement (Art. 17) / obligation comptable (Code de commerce Art. L123-22) — Les commandes doivent être conservées 10 ans ; elles ne peuvent donc pas être supprimées. La solution retenue est la **pseudonymisation** : lors d'une demande de suppression, le compte est désactivé et les données nominatives (email, nom, prénom, téléphone, adresse, ville) sont remplacées par des valeurs anonymes. L'historique d'achat subsiste à des fins comptables sans permettre d'identifier le client. Les comptes employés et administrateurs sont exclus de cette route.

4.2 Accessibilité (RGAA / WCAG 2.1 niveau AA)

- **Navigation au clavier** — Prise en charge complète de Tab, Entrée et Échap sur l'ensemble des composants interactifs (modales, menu mobile, formulaires).
- **Sémantique ARIA** — Le bouton hamburger porte un `aria-label` explicite et un `aria-expanded` mis à jour dynamiquement en JavaScript pour annoncer l'état ouvert / fermé aux lecteurs d'écran.
- **Structure HTML sémantique** — Chaque page utilise un unique `<header>`, `<main>` et `<footer>` ; les formulaires associent chaque `<label for>` à l'`id` de son champ ; les images décoratives portent un `alt=""`, les images informatives une description.
- **Contrastes** — Le texte principal (#2C1810) sur le fond crème (#F7F1E8) atteint un ratio de **15,02:1**, très au-delà du minimum de 4,5:1 exigé par le niveau AA et du seuil de 7:1 du niveau AAA. Le bordeaux (#5C1A1A) sur crème atteint 11,56:1, également conforme AAA.